

Website Vulnerability Scanner Report

✓ <https://aadarsh.1ngo.in/>

! The Light Website Scanner didn't check for critical issues like SQLi, XSS, Command Injection, XXE, etc.
[Upgrade to run Deep scans with 40+ tests](#) and detect more vulnerabilities.

Summary

Overall risk level:

Medium

Risk ratings:

Critical:	0
High:	0
Medium:	4
Low:	5
Info:	3

Scan information:

Start time:	Jun 03, 2026 / 23:12:35 UTC+0530
Finish time:	Jun 03, 2026 / 23:13:08 UTC+0530
Scan duration:	33 sec
Tests performed:	40
Scan status:	Finished

Findings

Insecure cookie setting: missing Secure flag

CONFIRMED

port 443/tcp

URL	Cookie Name	Evidence
https://aadarsh.1ngo.in/	csrftoken	Set-Cookie: csrftoken=Mos5OrlDtm15fvmmhlBFmVwUlsAPL0jD Request / Response

▼ Details

Risk description:

The risk exists that an attacker will intercept the clear-text communication between the browser and the server and he will steal the cookie of the user. If this is a session cookie, the attacker could gain unauthorized access to the victim's web session.

Recommendation:

Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html

Classification:

CWE : [CWE-614](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Insecure cookie setting: missing HttpOnly flag

CONFIRMED

port 443/tcp

URL	Cookie Name	Evidence
-----	-------------	----------

https://aadarsh.1ngo.in/	csrftoken	The server responded with Set-Cookie header(s) that does not specify the HttpOnly flag: Set-Cookie: csrftoken=Mos5OrlDtm15fvmmhIBFmVwUlsAPL0jD Request / Response
---	-----------	---

▼ Details

Risk description:

The risk is that an attacker who injects malicious JavaScript code on the page (e.g. by using an XSS attack) can access the cookie and can send it to another site. In case of a session cookie, this could lead to session hijacking.

Recommendation:

Ensure that the HttpOnly flag is set for all cookies.

References:

<https://owasp.org/www-community/HttpOnly>

Classification:

CWE : [CWE-1004](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)



Directory listing is enabled

CONFIRMED

port 443/tcp

URL	Evidence
https://aadarsh.1ngo.in/static/	Found output resembling directory listing. Request / Response
https://aadarsh.1ngo.in/static/assets/img/	Found output resembling directory listing. Request / Response
https://aadarsh.1ngo.in/static/assets/img/our_focus_area	Found output resembling directory listing. Request / Response

▼ Details

Risk description:

The risk is that it's often the case that sensitive files are "hidden" among public files in that location and attackers can use this vulnerability to access them.

Recommendation:

We recommend reconfiguring the web server in order to deny directory listing. Furthermore, you should verify that there are no sensitive files at the mentioned URLs.

References:

<http://projects.webappsec.org/w/page/13246922/Directory%20Indexing>

Classification:

CWE : [CWE-548](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A1 - Broken Access Control](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)



Vulnerabilities found for bootstrap 4.0.0

port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2024-6531	6.4	0.00072	0.22588	A vulnerability has been identified in Bootstrap that exposes users to Cross-Site Scripting (XSS) attacks. The issue is present in the carousel component, where the data-slide and data-slide-to attributes can be exploited through the href attribute of an <a> tag due to inadequate sanitization. This vulnerability could potentially enable attackers to execute arbitrary JavaScript within the victim's browser.

CVE-2018-14042	6.1	0.02281	0.84974	In Bootstrap before 4.1.2, XSS is possible in the data-container property of tooltip.
CVE-2018-14041	6.1	0.07723	0.92072	In Bootstrap before 4.1.2, XSS is possible in the data-target property of scrollspy.
CVE-2018-14040	6.1	0.01926	0.83695	In Bootstrap before 4.1.2, XSS is possible in the collapse data-parent attribute.
CVE-2016-10735	6.1	0.05337	0.90223	In Bootstrap 3.x before 3.4.0 and 4.x-beta before 4.0.0-beta.2, XSS is possible in the data-target attribute, a different vulnerability than CVE-2018-14041.

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.07723

EPSS percentile : 0.92072

CISA KEV: False

CVE : [CVE-2024-6531](#), [CVE-2018-14042](#), [CVE-2018-14041](#), [CVE-2018-14040](#), [CVE-2016-10735](#)

CVSS V3 : 6.4

CWE : [CWE-1035](#)

🚩 Missing security header: Content-Security-Policy

CONFIRMED

port 443/tcp

URL	Evidence
https://aadarsh.1ngo.in/	Response does not include the HTTP Content-Security-Policy security header or meta tag Request / Response

▼ Details

Risk description:

The risk is that if the target application is vulnerable to XSS, lack of this header makes it easily exploitable by attackers.

Recommendation:

Configure the Content-Security-Header to be sent with each HTTP response in order to apply the specific policies needed by the application.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>

Classification:

CWE : [CWE-1021](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 Missing security header: Strict-Transport-Security

CONFIRMED

port 443/tcp

URL	Evidence
-----	----------

<https://aadarsh.1ngo.in/>

Response headers do not include the HTTP Strict-Transport-Security header
[Request / Response](#)

▼ Details

Risk description:

The risk is that lack of this header permits an attacker to force a victim user to initiate a clear-text HTTP connection to the server, thus opening the possibility to eavesdrop on the network traffic and extract sensitive information (e.g. session cookies).

Recommendation:

The Strict-Transport-Security HTTP header should be sent with each HTTPS response. The syntax is as follows:

`Strict-Transport-Security: max-age=<seconds>[; includeSubDomains]`

The parameter `max-age` gives the time frame for requirement of HTTPS in seconds and should be chosen quite high, e.g. several months. A value below 7776000 is considered as too low by this scanner check.

The flag `includeSubDomains` defines that the policy applies also for sub domains of the sender of the response.

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 Missing security header: Referrer-Policy

CONFIRMED

port 443/tcp

URL	Evidence
https://aadarsh.1ngo.in/static/assets/img/our_focus_area	Response headers do not include the Referrer-Policy HTTP security header as well as the <meta> tag with name 'referrer' is not present in the response. Request / Response

▼ Details

Risk description:

The risk is that if a user visits a web page (e.g. "http://example.com/pricing/") and clicks on a link from that page going to e.g. "https://www.google.com", the browser will send to Google the full originating URL in the `Referer` header, assuming the Referrer-Policy header is not set. The originating URL could be considered sensitive information and it could be used for user tracking.

Recommendation:

The Referrer-Policy header should be configured on the server side to avoid user tracking and inadvertent information leakage. The value `no-referrer` of this header instructs the browser to omit the Referer header entirely.

References:

https://developer.mozilla.org/en-US/docs/Web/Security/Referer_header:_privacy_and_security_concerns

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 Missing security header: X-Content-Type-Options

CONFIRMED

port 443/tcp

URL	Evidence
https://aadarsh.1ngo.in/static/assets/img/our_focus_area	Response headers do not include the X-Content-Type-Options HTTP security header Request / Response

▼ Details

Risk description:

The risk is that lack of this header could make possible attacks such as Cross-Site Scripting or phishing in Internet Explorer browsers.

Recommendation:

We recommend setting the X-Content-Type-Options header such as `X-Content-Type-Options: nosniff`.

References:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options>

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Server software and technology found

port 443/tcp

UNCONFIRMED ⓘ

Software / Version	Category
 Twitter Ads	Advertising
 cdnjs	CDN
 jQuery CDN	CDN
 Facebook Login	Authentication
 Magnific Popup	JavaScript libraries
 Django	Web frameworks
 Font Awesome 5.15.4	Font scripts
 Google Font API	Font scripts
 Bootstrap 4.0.0	UI frameworks
 core-js 2.5.1	JavaScript libraries
 Google Analytics GA4	Analytics
 HTTP/3	Miscellaneous
Isotope	JavaScript libraries
 jQuery 3.5.1	JavaScript libraries
Slick 1.9.0	JavaScript libraries
 Leaflet 1.7.1	Maps
 Livefyre 1.7.1	Comment systems
 Google Maps	Maps
 Masonry	JavaScript libraries
 AOS	JavaScript libraries
 MySQL	Databases
 OWL Carousel	JavaScript libraries
 PHP	Programming languages
 Popper 1.12.9	Miscellaneous
 Python	Programming languages
 Sentry	Issue trackers
 DoubleClick Floodlight	Advertising
SweetAlert2 11	JavaScript libraries
 Twitter	Widgets

 Unpkg	CDN
 WordPress	CMS, Blogs
 Cloudflare	CDN
 DigitalOcean Spaces	CDN, IaaS
 reCAPTCHA	Security
 Google Tag Manager	Tag managers
 jsDelivr	CDN
 Thinkstack	Development

Details

Risk description:

The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:

We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server.html

Classification:

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

File Upload

port 443/tcp

CONFIRMED

URL	Method	Parameters	Evidence
https://aadarsh.1ngo.in/	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	The following form allows file upload: <pre><form action="/addmobileActivity" method="post" role="form" enctype="multipart/form-data"> <input type="hidden" name="csrfmiddlewaretoken" value="3lZngfMnmhtwrpHIj0fgesBFSCW9eFzhiUwXQyy8oBMPB0TKjrlAcMXihiMiH"> <div class="form-group" id="action-form"> <p>Upload an image:</p> <input type="file" name="image[]" accept="image/*" onchange="loadFiles(event)" multiple>
 <p class="image-count-warning" style="color: red; display: none;">Maximum 3 images allowed</p> <div id="image-previews"></div> <input type="hidden" name="key" value="upworkproject_gururajpotnis">
 </div> <div class="form-group"> <label for="">Headline</label> <input class="form-control input-char-count" id="action-form" name="headline" placeholder="Headline" type="text" maxlength="100" required> </div> <div class="form-group"> <label for="">Description</label> <textarea class="form-control input-char-count" id="action-form" type="text" name="text" placeholder="Text" maxlength="1000" rows="5"></textarea> </div> <div class="form-group"> <label for="">Date</label> </div> </form></pre> ... (truncated) Request / Response

▼ Details

Risk description:

The risk is that an attacker might use the file upload functionality for path traversal, persistent XSS, transmission of malware or denial of service, if such vulnerabilities are present.

Recommendation:

Use a server-generated filename, inspect the content of uploaded files, enforce a whitelist of non-executable file types and a size limit, and reject attempts to upload archive formats such as ZIP.

References:

<https://cwe.mitre.org/data/definitions/434.html>

Classification:

CWE : [CWE-434](#)

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)



Security.txt file is missing

CONFIRMED

port 443/tcp

URL

Missing: <https://aadarsh.1ngo.in/.well-known/security.txt>

▼ Details

Risk description:

There is no particular risk in not having a security.txt file for your server. However, this file is important because it offers a designated channel for reporting vulnerabilities and security issues.

Recommendation:

We recommend you to implement the security.txt file according to the standard, in order to allow researchers or users report any security issues they find, improving the defensive mechanisms of your server.

References:

<https://securitytxt.org/>

Classification:

CWE : [CWE-1188](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)



Email Address Exposure

UNCONFIRMED ⓘ

port 443/tcp

URL	Method	Parameters	Evidence
https://aadarsh.1ngo.in/	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Email Address: anjalisrivastava1973@gmail.com Request / Response

▼ Details

Risk description:

The risk is that exposed email addresses within the application could be accessed by unauthorized parties. This could lead to privacy violations, spam, phishing attacks, or other forms of misuse.

Recommendation:

Compartmentalize the application to have 'safe' areas where trust boundaries can be unambiguously drawn. Do not allow email addresses to go outside of the trust boundary, and always be careful when interfacing with a compartment outside of the safe area.

References:

https://owasp.org/Top10/A04_2021-Insecure_Design/

Classification:

CISA KEV: False

CVE : -1
CWE : [CWE-200](#)
OWASP Top 10 - 2017 : A6: Security Misconfiguration
OWASP Top 10 - 2021 : A4: Insecure Design
OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Scan coverage information

List of tests performed (40)

Port 443

- ✓ Scanned for directory listing
- ✓ Scanned for HttpOnly flag of cookie
- ✓ Scanned for Secure flag of cookie
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for missing HTTP header - Content Security Policy
- ✓ Scanned for missing HTTP header - Referrer
- ✓ Scanned for missing HTTP header - Strict-Transport-Security
- ✓ Scanned for missing HTTP header - X-Content-Type-Options
- ✓ Scanned for website technologies
- ✓ Scanned for emails
- ✓ Scanned for file upload
- ✓ Scanned for absence of the security.txt file
- ✓ Scanned for client access policies
- ✓ Scanned for robots.txt file
- ✓ Scanned for use of untrusted certificates
- ✓ Scanned for enabled HTTP debug methods
- ✓ Scanned for enabled HTTP OPTIONS method
- ✓ Scanned for secure communication
- ✓ Scanned for passwords submitted unencrypted
- ✓ Scanned for error messages
- ✓ Scanned for debug messages
- ✓ Scanned for code comments
- ✓ Scanned for passwords submitted in URLs
- ✓ Scanned for domain too loose set for cookies
- ✓ Scanned for mixed content between HTTP and HTTPS
- ✓ Scanned for cross domain file inclusion
- ✓ Scanned for internal error code
- ✓ Scanned for login interfaces
- ✓ Scanned for secure password submission
- ✓ Scanned for sensitive data
- ✓ Scanned for unsafe HTTP header Content Security Policy
- ✓ Scanned for OpenAPI files
- ✓ Scanned for SQL statement in request parameter
- ✓ Scanned for password returned in later response
- ✓ Scanned for Path Disclosure
- ✓ Scanned for Session Token in URL
- ✓ Scanned for API endpoints
- ✓ Scanned for missing HTTP header - Rate Limit
- ✓ Scanned for PEM-encoded private key material
- ✓ Scanned for partial PEM-encoded private key material

Scan parameters

target:	https://aadarsh.1ngo.in/
scan_type:	Light
authentication:	False

Scan stats

Unique Injection Points Detected:	78
URLs spidered:	16
Total number of HTTP requests:	26

Average time until a response was received:	389ms
---	-------